Defect Report

Employee REST API – API Testing (Postman and Newman)

Joinab Binte Siraj Asifa
SQALOGY
25th October 2026

Table of Contents

1 Document Control....3
2 Executive Summary....3
3 Test Environment....3
4 Defect Metrics....3
5 Defect Summary....4
6 Detailed Defect Description....5
6.1 BUG-01: Negative, non-numeric and out-of-range salary accepted on create....5
6.2 BUG-02: Negative and non-numeric salary accepted on update....5
6.3 BUG-03: Invalid email format accepted on create and update....6
6.4 BUG-04: Duplicate email accepted when letter case differs....6
6.5 BUG-05: Invalid status handled inconsistently on create and update....7
6.6 BUG-06: First name accepts blank, numeric and 300-character values....7
6.7 BUG-07: Invalid hireDate format accepted on create....8
6.8 BUG-08: HTML and script content stored unsanitised (stored XSS)....8
6.9 BUG-09: Invalid or expired token returns 403 instead of 401....9
6.10 BUG-10: limit query parameter is not validated....9
6.11 BUG-11: page query parameter is not validated....10
7 Test Evidence....11
8 Observations....13
9 Recommendation....14
10 Conclusion....14

1 Document Control

Version	Date	Author	Description
1.0	25-10-2026	Joinab Binte Siraj Asifa	Initial defect report submission

2 Executive Summary

This document provides a detailed overview of the defects identified during functional and negative testing of the Employee REST API. Tests were designed and executed with Postman, automated with Newman, and each failure was reviewed manually before being logged as a defect.

The objective of this report is to summarize the discovered issues, classify their severity, and provide recommendations for improvement. The final test run executed 110 test cases; 84 passed and 26 failed. All 26 failed test cases trace to 11 distinct defects.

3 Test Environment

- Application: Employee REST API
- URL: https://crudapi-o7rr.onrender.com
- Testing Type: Automated functional, negative and security-oriented API testing
- Tools: Postman (collection of 110 requests) and Newman with the htmlextra reporter
- Postman Environment: SqalogyB3TestEnv
- Test Run: Saturday 24 October 2026, 21:48 (UTC+6), duration 1 minute 14.6 seconds
- Platform: macOS, Node.js v22.19.0

4 Defect Metrics

Metric	Count
Total Test Cases Executed	110
Test Cases Passed	84
Test Cases Failed	26
Total Defects Identified	11
Critical Defects	0
High Severity Defects	3
Medium Severity Defects	4
Low Severity Defects	4

Newman reports 40 failed assertions out of 214. For requests followed by an automatic cleanup call, the report lists each failed assertion twice, so the 26 failed test cases appear as 40 failed assertions.

5 Defect Summary

Bug ID	Title	Severity	Test Cases	Status
BUG-01	Negative, non-numeric and out-of-range salary accepted on create	High	TC17, TC42, TC66, TC67	Open
BUG-02	Negative and non-numeric salary accepted on update	High	TC46, TC98	Open
BUG-03	Invalid email format accepted on create and update	Medium	TC15, TC95	Open
BUG-04	Duplicate email accepted when letter case differs	Medium	TC75	Open
BUG-05	Invalid status handled inconsistently on create and update	Medium	TC45, TC96	Open
BUG-06	First name accepts blank, numeric and 300-character values	Low	TC44, TC69, TC70	Open
BUG-07	Invalid hireDate format accepted on create	Medium	TC61	Open
BUG-08	HTML and script content stored unsanitised (stored XSS)	High	TC74, TC103	Open
BUG-09	Invalid or expired token returns 403 instead of 401	Low	TC73, TC91, TC104, TC108	Open
BUG-10	limit query parameter is not validated	Low	TC49, TC80, TC81	Open
BUG-11	page query parameter is not validated	Low	TC82, TC83	Open

6 Detailed Defect Description

Record ids quoted below come from the final run and will differ on a repeat. The cleanup call in the Newman run returns the stored record, which proves the values were saved and not only accepted.

6.1 BUG-01: Negative, non-numeric and out-of-range salary accepted on create

Module: Employee Management – Create Employee (POST /api/employees)

Steps to Reproduce

1. Log in as admin (POST /api/auth/login) and copy the token.
2. Send POST /api/employees with a valid body but "salary": -5000.
3. Repeat with "salary": "abc", "salary": "50000" (a string) and "salary": 9999999999999.

Expected Result

The API should return 400 Bad Request with a validation message. Salary must be a positive number within a sensible range.

Actual Result

The API returns 201 Created for every value. The stored records show -5000 (id 10), "abc" (id 11), 9999999999999 (id 18) and "50000" stored as a string (id 19).

Impact: Payroll data is corrupted and salary calculations will fail or give wrong results.

Test Cases: TC17, TC42, TC66, TC67

Severity: **High**

6.2 BUG-02: Negative and non-numeric salary accepted on update

Module: Employee Management – Update Employee (PATCH /api/employees/:id)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send PATCH /api/employees/{id} with the body {"salary": -100}.
3. Repeat with the body {"salary": "lots"}.

Expected Result

The API should return 400 Bad Request, applying the same salary rules as on create.

Actual Result

The API returns 200 OK with the message "Employee updated successfully". The record (id 6) now holds salary -100, and later "lots".

Impact: Validation applied on create can be bypassed by updating the record afterwards.

Test Cases: TC46, TC98

Severity: **High**

6.3 BUG-03: Invalid email format accepted on create and update

Module: Employee Management – Create and Update Employee

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send POST /api/employees with "email": "invalid-email-1792856870" (no @ and no domain).
3. Send PATCH /api/employees/{id} with the body {"email": "not-an-email"}.

Expected Result

The API should return 400 Bad Request with an email-format error.

Actual Result

The create request returns 201 Created and stores the invalid email (id 9). The update request returns 200 OK and the record (id 6) now has the email "not-an-email".

Impact: Unusable contact data is stored. Email is used for identity, filtering and duplicate checks.

Test Cases: TC15, TC95

Severity: **Medium**

6.4 BUG-04: Duplicate email accepted when letter case differs

Module: Employee Management – Create Employee (POST /api/employees)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Take an existing employee's email, for example cheyenne.gaylord.179285686912771@company.com (id 8).
3. Send POST /api/employees with the same address in upper case, CHEYENNE.GAYLORD.179285686912771@COMPANY.COM, and a different phone number.

Expected Result

The API should return 409 Conflict (or 400 Bad Request). Email addresses are case-insensitive in practice.

Actual Result

The API returns 201 Created and stores a second record (id 24) with the upper-case email. An exact duplicate is correctly rejected (TC16), and the email filter is case-insensitive (TC89), so a search by this email returns both records.

Impact: Duplicate employee records exist for a single email address.

Test Cases: TC75

Severity: **Medium**

6.5 BUG-05: Invalid status handled inconsistently on create and update

Module: Employee Management – Create and Update Employee

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send POST /api/employees with "status": "xyz".
3. Send PATCH /api/employees/{id} with the body {"status": "banana"}.

Expected Result

The API should return 400 Bad Request and list the allowed status values.

Actual Result

On create the API returns 201 Created and silently replaces the value with "active" (id 13). On update the API returns 200 OK and stores the arbitrary value "banana" (id 6).

Impact: The client is not told that its input was rejected. Arbitrary statuses break status filters and business rules.

Test Cases: TC45, TC96

Severity: **Medium**

6.6 BUG-06: First name accepts blank, numeric and 300-character values

Module: Employee Management – Create Employee (POST /api/employees)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send POST /api/employees with "firstName": " " (a single space).
3. Repeat with "firstName": "J0hn123" and with a 300-character string of the letter A.

Expected Result

The API should return 400 Bad Request. A first name should be non-blank, contain letters only and have a maximum length.

Actual Result

The API returns 201 Created for all three values, and they are stored as sent (ids 21, 22 and 12). A completely empty first name is correctly rejected (TC43).

Impact: Poor data quality. Very long names can break user-interface layouts and reports.

Test Cases: TC44, TC69, TC70

Severity: **Low**

6.7 BUG-07: Invalid hireDate format accepted on create

Module: Employee Management – Create Employee (POST /api/employees)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send POST /api/employees with "hireDate": "15-31-2024" (an impossible date).

Expected Result

The API should return 400 Bad Request for an invalid date.

Actual Result

The API returns 201 Created and the record (id 15) stores "hireDate": "15-31-2024".

Impact: Date-based sorting, filtering and reporting break.

Test Cases: TC61

Severity: **Medium**

6.8 BUG-08: HTML and script content stored unsanitised (stored XSS)

Module: Employee Management – Create and Update Employee

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send POST /api/employees with "firstName": "<script>alert(1)</script>".
3. Send PATCH /api/employees/{id} with the body {"position": "<img src=x onerror=alert(1)>"}.

Expected Result

The payload should be rejected with 400 Bad Request, or sanitised or encoded before it is stored.

Actual Result

Both requests succeed, and the payloads are stored and returned unchanged (ids 23 and 6).

Impact: Any web or mobile client that renders these fields without escaping is open to stored cross-site scripting (OWASP A03: Injection).

Test Cases: TC74, TC103

Severity: **High**

6.9 BUG-09: Invalid or expired token returns 403 instead of 401

Module: Authentication – all protected endpoints

Steps to Reproduce

1. Send POST, GET, PATCH or DELETE to any /api/employees endpoint.
2. Set the header Authorization: Bearer invalid.token.value.

Expected Result

The API should return 401 Unauthorized, because authentication has failed.

Actual Result

The API returns 403 Forbidden with the message "Invalid or expired token". A missing token correctly returns 401, so the behaviour is inconsistent.

Impact: Clients that treat 401 as "log in again" will not refresh an expired session.

Test Cases: TC73, TC91, TC104, TC108

Severity: **Low**

6.10 BUG-10: limit query parameter is not validated

Module: Employee Management – Get All Employees (GET /api/employees)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send GET /api/employees?limit=-1.
3. Repeat with limit=0 and with limit=abc.

Expected Result

The API should return 400 Bad Request because limit must be an integer of at least 1.

Actual Result

The API returns 200 OK in all cases. limit=-1 returns an employee list. limit=0 and limit=abc return an empty data array with "totalPages": null and "limit" set to 0 or null.

Impact: Pagination metadata is inconsistent and clients fail silently.

Test Cases: TC49, TC80, TC81

Severity: **Low**

6.11 BUG-11: page query parameter is not validated

Module: Employee Management – Get All Employees (GET /api/employees)

Steps to Reproduce

1. Log in as admin and copy the token.
2. Send GET /api/employees?page=0.
3. Repeat with page=-5.

Expected Result

The API should return 400 Bad Request because page must be 1 or greater.

Actual Result

The API returns 200 OK with an empty data array and echoes "currentPage": 0 or -5.

Impact: Invalid paging input is accepted and gives misleading empty results.

Test Cases: TC82, TC83

Severity: **Low**

7 Test Evidence

The figures below are taken from the Newman HTML report of the final run. Each failed assertion shows the expected and the actual result.

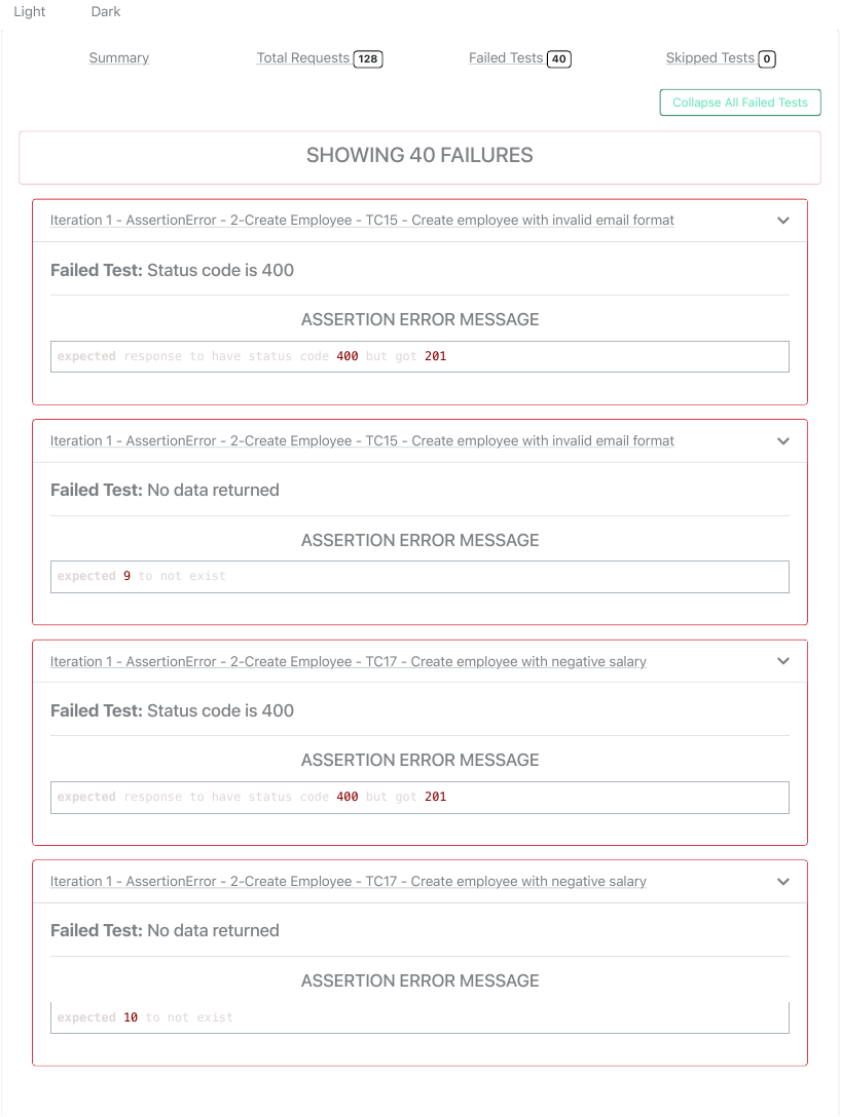


Figure 1: Newman report summary and failures for TC15 (invalid email) and TC17 (negative salary)

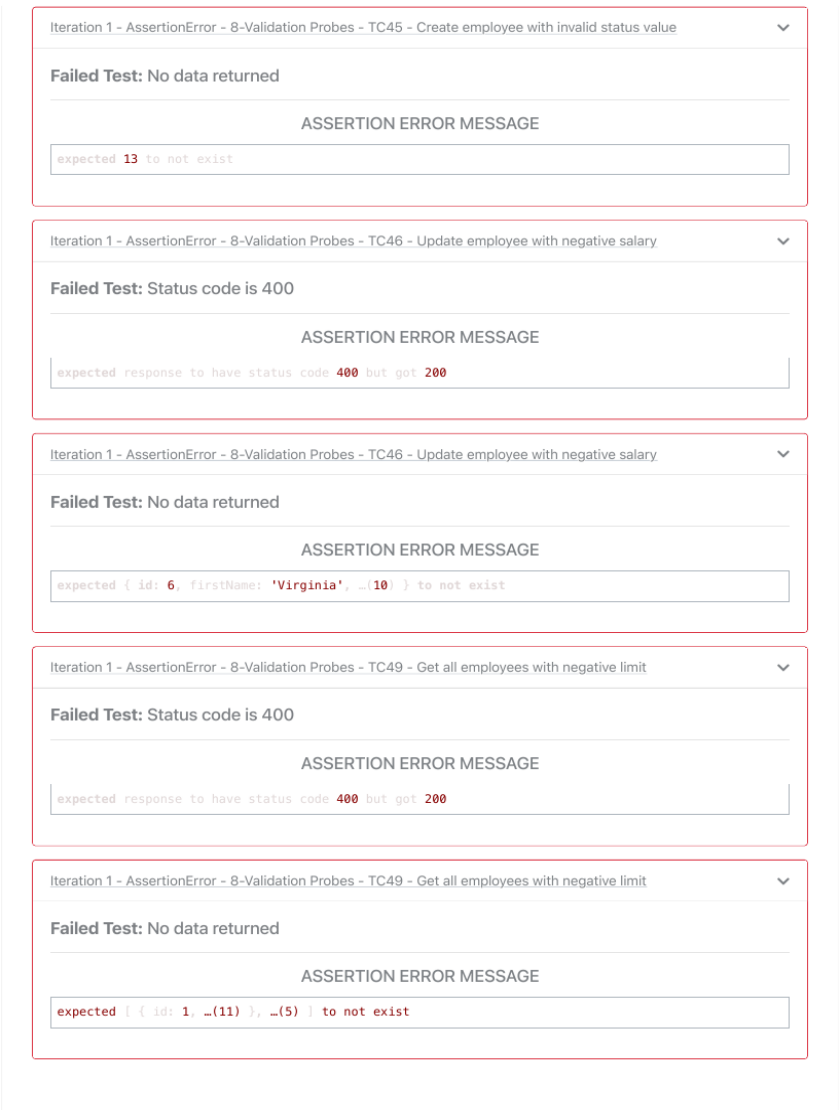


Figure 2: Newman report failures for TC45, TC46 (negative salary on update) and TC49 (negative limit)

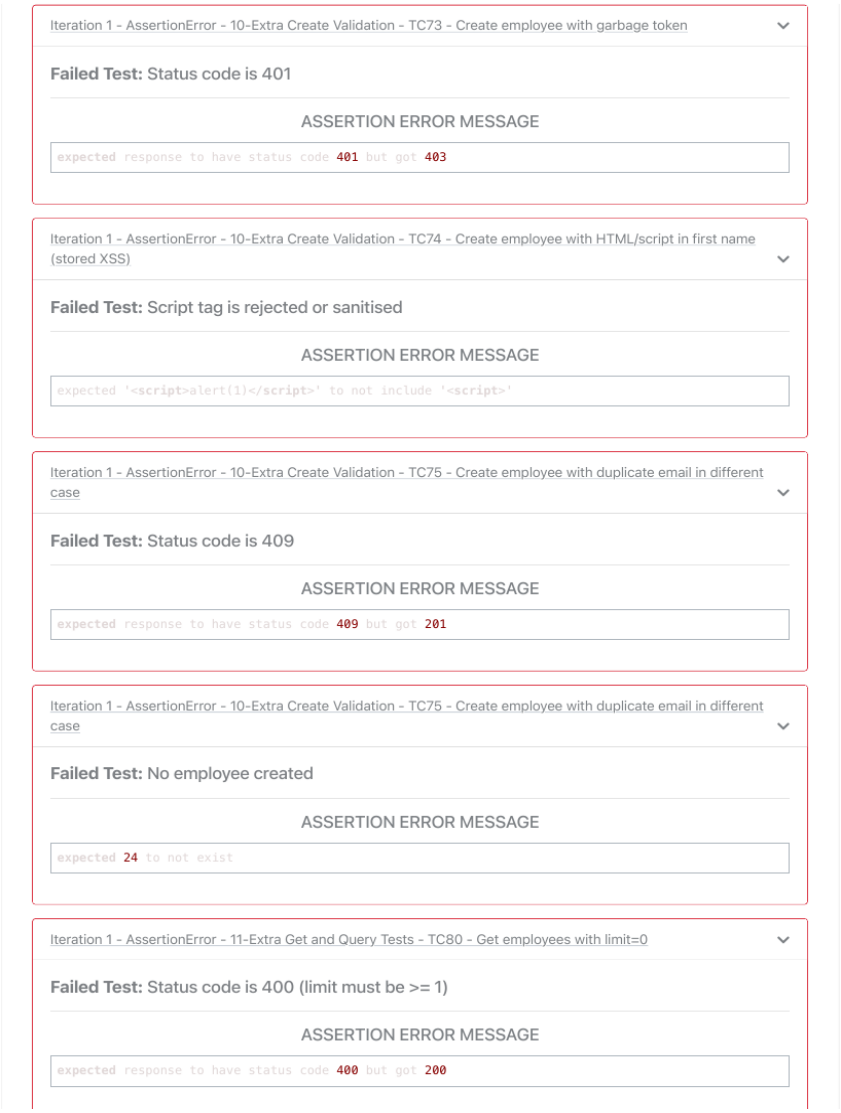


Figure 3: Newman report failures for TC73 (token), TC74 (stored XSS), TC75 (duplicate email) and TC80 (limit=0)

8 Observations

The following behaviours were observed. They are not logged as defects because the API documentation does not state a rule, and each needs confirmation against the business requirements. The related tests assert the observed behaviour and pass.

- Login with numeric username and password (TC53) returns 401 instead of 400.
- Salary is not a required field. A missing salary defaults to 0, and a salary of 0 is accepted (TC60, TC65).
- Department accepts any text, for example "Underwater Basket Weaving" (TC68). No list of allowed values is documented.
- A future hire date (2099-01-01) is accepted (TC62).
- A path-injection probe on /api/employees/1 OR 1=1 (TC92) was blocked by an infrastructure firewall (HTML page, 403) before reaching the API, so the API's own handling was not assessed.
- The first request after an idle period took about 22 seconds in the first run (hosting cold start); later requests took about 250 to 400 milliseconds.

9 Recommendation

Based on the identified defects, improvements are recommended in the following areas:

- Server-side validation schema (for example Joi or Zod) for every field on both create and update: type, range, length, format and allowed values
- Sanitising or encoding HTML special characters in text fields
- Case-insensitive uniqueness check for email, backed by a unique index on the lower-case value
- Returning 401 for every authentication failure (missing, malformed or expired token)
- Validation of pagination parameters (page of at least 1, limit between 1 and a maximum)

10 Conclusion

The testing process identified 11 defects in the Employee REST API: 3 of High severity, 4 of Medium severity and 4 of Low severity. Core workflows (login, creating, reading, updating and deleting employees, required-field checks, phone validation and query filters) function correctly, but the gaps in input validation, input sanitising and error status codes should be addressed to protect data integrity and security.